

A previously unknown threat activity cluster targeted European organizations, particularly those in the healthcare sector, to deploy PlugX and its successor, ShadowPad, with the intrusions ultimately leading to deployment of a ransomware called NailaoLocker in some cases.

The campaign, codenamed Green Nailao by Orange Cyberdefense CERT, involved the exploitation of a now-patched security flaw in Check Point network gateway security products ([CVE-2024-24919](#), CVSS score: 7.5). The attacks were observed between June and October 2024.

"The campaign relied on DLL search-order hijacking to deploy ShadowPad and PlugX – two implants often associated with China-nexus targeted intrusions," the company [said](#) in a technical report shared with The Hacker News.

The initial access afforded by exploitation of vulnerable Check Point instances is said to have allowed the threat actors to retrieve user credentials and to connect to the VPN using a legitimate account.

In the next stage, the attackers carried out network reconnaissance and lateral movement via remote desktop protocol (RDP) to obtain elevated privileges, followed by executing a legitimate binary ("logger.exe") to sideload a rogue DLL ("logexts.dll") that then serves as a loader for a new version of the [ShadowPad](#) malware.

Previous iterations of the attacks detected in August 2024 have been found to leverage similar tradecraft to deliver [PlugX](#), which also employs DLL side-loading using a McAfee executable ("mcoemcpy.exe") to sideload "McUtil.dll."

Like PlugX, ShadowPad is a privately sold malware that's exclusively used by Chinese espionage actors since at least 2015. The variant identified by Orange Cyberdefense CERT features sophisticated obfuscation and anti-debug measures, alongside establishing communication with a remote server to create persistent remote access to victim systems.

There is evidence to suggest that the threat actors attempted to exfiltrate data by accessing the file system and creating ZIP archives. The intrusions culminate with the use of Windows Management Instrumentation (WMI) to transmit three files, a legitimate executable signed by

Beijing Huorong Network Technology Co., Ltd ("usysdiag.exe"), a loader named NailaoLoader ("sensapi.dll"), and NailaoLocker ("usysdiag.exe.dat").

Once again, the DLL file is sideloaded via "usysdiag.exe" to decrypt and trigger the execution of NailaoLocker, a C++-based ransomware that encrypts files, appends them with a ".locked" extension, and drops a ransom note that demands victims to make a bitcoin payment or contact them at a Proton Mail address.

"NailaoLocker is relatively unsophisticated and poorly designed, seemingly not intended to guarantee full encryption," researchers Marine Pichon and Alexis Bonnefoi said.

"It does not scan network shares, it does not stop services or processes that could prevent the encryption of certain important files, [and] it does not control if it is being debugged."